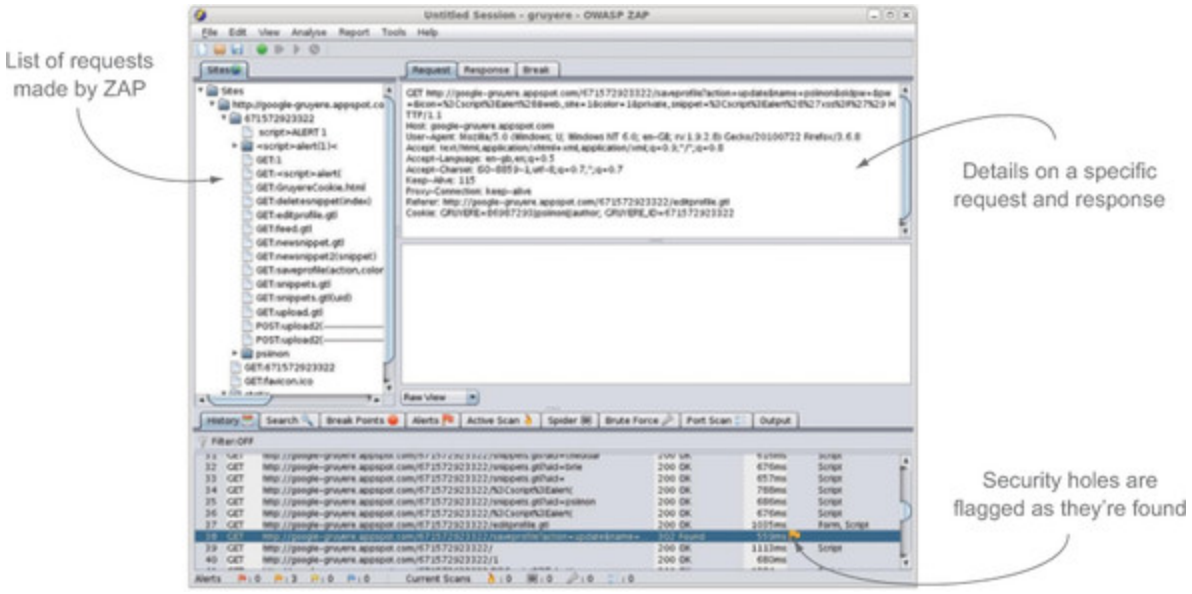
Security is a big enough topic for a completely separate book, but if you're not sure where to start, here are some tips.

Memorize the Open Web Application Security Project (OWASP) top 10.[5] Note that the details on this page sometimes gets out of date but the list remains valid. There's a list for mobile applications as well as one for web applications. These lists give you the 10 most important things to keep in mind as you're designing a secure software product.

[5] Tips for designing secure software, www.owasp.org/index.php/OWASP_Top_Ten_Cheat_Sheet.

OWASP ZAP is a great way get started doing security scanning on your application. ZAP will use a spider to crawl through your site and use common hacking techniques to attack it and report back on vulnerabilities. An example of ZAP is shown in figure 8.17.

Figure 8.17. An example screenshot of OWASP ZAP



If your site fails security analysis, you should stop whatever you're doing and fix the problems. Suffice it to say that a site with poor security has very low usability.